Empresa Ejemplo S.A.
Gerencia de Arquitectura y Desarrollo de Software

Marco de Referencia de Estándares Externos

OWASP ASVS, MASVS, Top 10 y API Security Top 10

Código	Versión	Fecha de aprobación	Estado
EST-REF-001	1.3	2026-03-10	Vigente

Aprobado por: Seguridad de la Información

Documento de prueba con contenido ficticio. La empresa y las reglas son un ejemplo para pruebas de un asistente RAG; no corresponden a ninguna organización real.

Control de cambios

Versión	Fecha	Descripción del cambio
1.0	2022-05-02	Versión inicial: OWASP Top 10 2017.
1.2	2024-09-16	Adopción de ASVS 4.0.3, MASVS 2.0 y Top 10 2021.
1.3	2026-03-10	Se agrega OWASP API Security Top 10 2023 y el grupo MASVS-PRIVACY.

Contenido

Control de cambios . . . 2
1. Objetivo . . . 3
2. Alcance . . . 3
3. Definiciones y niveles de cumplimiento . . . 3
4. Versiones y niveles adoptados . . . 3
5. OWASP Top 10 (2021) . . . 4
6. OWASP API Security Top 10 (2023) . . . 5
7. OWASP ASVS 4.0.3 por capítulo . . . 7
8. OWASP MASVS 2.x por grupo de controles . . . 9
9. Fuentes oficiales . . . 10

1. Objetivo

Indicar qué estándares externos adopta la empresa, en qué versión y con qué nivel de exigencia, y relacionar cada control externo con las reglas internas que lo implementan.

2. Alcance

Complementa a EST-SEG-001, EST-API-001, EST-WEB-001 y EST-DSK-001. Este documento es un resumen interno: ante cualquier duda de interpretación prevalece la publicación oficial de OWASP (owasp.org). Los textos de cada control son paráfrasis, no traducciones literales.

3. Definiciones y niveles de cumplimiento

Término	Definición
Obligatorio	La regla debe cumplirse en todo desarrollo nuevo y en todo cambio sobre código existente. Su incumplimiento bloquea el pase a producción salvo excepción aprobada.
Recomendado	Buena práctica esperada. Su incumplimiento no bloquea el pase, pero debe justificarse en la revisión de código.
Prohibido	Práctica que no debe aparecer en el código. Equivale a una regla obligatoria en sentido negativo.
Excepción	Autorización temporal (máximo 6 meses) para no cumplir una regla obligatoria. La aprueba el Comité de Arquitectura y, si la regla es de seguridad, también Seguridad de la Información. Se registra en el formulario FOR-ARQ-07.
OWASP	Open Worldwide Application Security Project, fundación sin fines de lucro que publica guías abiertas de seguridad de aplicaciones.
Nivel de verificación	Grado de rigor con que se verifica una aplicación: L1, L2 o L3 en ASVS; MAS-L1, MAS-L2 y MAS-R en MASVS.

4. Versiones y niveles adoptados

4.1 REF-NIV-001 · Nivel ASVS exigido según el tipo de aplicación

Nivel: Obligatorio | **Aplica a:** Web, API | **Referencias:** OWASP ASVS 4.0.3

Nivel L1: aplicaciones internas sin datos sensibles. Nivel L2 (nivel por defecto): toda aplicación web o API que procese datos sensibles o que esté expuesta a internet. Nivel L3: sistemas transaccionales core, pagos y aplicaciones que administran identidades. El nivel se registra en la ficha de arquitectura de cada sistema.

4.2 REF-NIV-002 · Perfil MASVS exigido para aplicaciones móviles

Nivel: Obligatorio | **Aplica a:** Móvil | **Referencias:** OWASP MASVS 2.x; OWASP MASTG

MAS-L1 para aplicaciones informativas. MAS-L2 para aplicaciones que manejan datos de clientes. Las aplicaciones con transacciones monetarias cumplen MAS-L2 más los controles de resiliencia (MAS-R). La verificación se realiza con la guía de pruebas MASTG.

4.3 REF-NIV-003 · Versiones vigentes de los estándares externos

Nivel: Obligatorio | **Aplica a:** Web, Móvil, Escritorio, API | **Referencias:** OWASP

Versiones adoptadas: ASVS 4.0.3 (la migración a ASVS 5.0 está planificada; mientras tanto los identificadores de requisitos citados en los estándares internos corresponden a la 4.0.3), MASVS 2.x, OWASP Top 10 edición 2021 y OWASP API Security Top 10 edición 2023. Seguridad de la Información revisa las versiones una vez al año.

5. OWASP Top 10 (2021)

Lista de concienciación de los diez riesgos más críticos en aplicaciones web. No es un estándar verificable por sí mismo: los requisitos verificables están en ASVS.

5.1 REF-T10-A01 · A01:2021 - Pérdida de control de acceso

Nivel: Obligatorio | **Aplica a:** Web, API | **Referencias:** A01:2021

Usuarios que actúan fuera de sus permisos: acceso a datos de otros usuarios cambiando identificadores, elevación de privilegios, APIs sin control de acceso en operaciones de escritura.

Reglas internas relacionadas: SEG-GEN-002, SEG-GEN-003, SEG-ACC-001, SEG-ACC-002, SEG-ACC-003.

5.2 REF-T10-A02 · A02:2021 - Fallas criptográficas

Nivel: Obligatorio | **Aplica a:** Web, API | **Referencias:** A02:2021

Datos sensibles sin cifrar en tránsito o en reposo, algoritmos débiles u obsoletos, claves embebidas en el código y generación de aleatorios predecibles.

Reglas internas relacionadas: SEG-AUT-002, SEG-CRI-001, SEG-CRI-002, SEG-CRI-004, SEG-CRI-005.

5.3 REF-T10-A03 · A03:2021 - Inyección

Nivel: Obligatorio | **Aplica a:** Web, API | **Referencias:** A03:2021

Datos no confiables interpretados como comandos o consultas: SQL, comandos del sistema operativo, LDAP y XSS (que en esta edición se incluye en inyección).

Reglas internas relacionadas: SEG-INY-001, SEG-INY-002, SEG-INY-003, SEG-INY-004.

5.4 REF-T10-A04 · A04:2021 - Diseño inseguro

Nivel: Obligatorio | **Aplica a:** Web, API | **Referencias:** A04:2021

Debilidades de diseño que ninguna implementación perfecta corrige: ausencia de modelado de amenazas, flujos de negocio sin límites, falta de controles en la arquitectura.

Reglas internas relacionadas: SEG-GEN-001, SEG-INY-007, SEG-CFG-004.

5.5 REF-T10-A05 · A05:2021 - Configuración de seguridad incorrecta

Nivel: Obligatorio | **Aplica a:** Web, API | **Referencias:** A05:2021

Configuraciones por defecto, mensajes de error detallados, cabeceras de seguridad ausentes, CORS permisivo, servicios innecesarios habilitados y procesadores XML con entidades externas.

Reglas internas relacionadas: SEG-CRI-003, SEG-LOG-003, SEG-CFG-001, SEG-CFG-002, SEG-INY-006.

5.6 REF-T10-A06 · A06:2021 - Componentes vulnerables y desactualizados

Nivel: Obligatorio | **Aplica a:** Web, API | **Referencias:** A06:2021

Uso de bibliotecas, frameworks o plataformas con vulnerabilidades conocidas o sin soporte del fabricante, y falta de un inventario de dependencias.

Reglas internas relacionadas: SEG-CFG-003, SEG-CFG-004.

5.7 REF-T10-A07 · A07:2021 - Fallas de identificación y autenticación

Nivel: Obligatorio | **Aplica a:** Web, API | **Referencias:** A07:2021

Contraseñas débiles, falta de protección contra fuerza bruta, ausencia de MFA, manejo inseguro de sesiones y tokens.

Reglas internas relacionadas: SEG-AUT-001 a SEG-AUT-006.

5.8 REF-T10-A08 · A08:2021 - Fallas de integridad de software y datos

Nivel: Obligatorio | **Aplica a:** Web, API | **Referencias:** A08:2021

Deserialización insegura, actualizaciones sin verificación de firma y pipelines de CI/CD que permiten introducir código no autorizado.

Reglas internas relacionadas: SEG-INY-005, SEG-DSK-003.

5.9 REF-T10-A09 · A09:2021 - Fallas en el registro y monitoreo

Nivel: Obligatorio | **Aplica a:** Web, API | **Referencias:** A09:2021

Eventos de seguridad no registrados, logs sin información útil o con datos sensibles, y ausencia de alertas que permitan detectar un ataque en curso.

Reglas internas relacionadas: SEG-LOG-001, SEG-LOG-002.

5.10 REF-T10-A10 · A10:2021 - Falsificación de solicitudes del lado del servidor (SSRF)

Nivel: Obligatorio | **Aplica a:** Web, API | **Referencias:** A10:2021

El servidor realiza peticiones a una URL que controla el atacante, lo que permite alcanzar servicios internos o metadatos de la nube.

Reglas internas relacionadas: API-SEG-005.

6. OWASP API Security Top 10 (2023)

6.1 REF-API-01 · API1:2023 - Autorización rota a nivel de objeto (BOLA)

Nivel: Obligatorio | **Aplica a:** API | **Referencias:** API1:2023

La API no verifica que el usuario tenga derecho sobre el objeto concreto cuyo identificador recibe.

Reglas internas relacionadas: SEG-ACC-002, API-SEG-002.

6.2 REF-API-02 · API2:2023 - Autenticación rota

Nivel: Obligatorio | **Aplica a:** API | **Referencias:** API2:2023

Mecanismos de autenticación mal implementados: tokens sin validar, credenciales en la URL, falta de límites de intentos.

Reglas internas relacionadas: SEG-AUT-004, SEG-AUT-006, API-SEG-001.

6.3 REF-API-03 · API3:2023 - Autorización rota a nivel de propiedad

Nivel: Obligatorio | **Aplica a:** API | **Referencias:** API3:2023

La API expone propiedades que el usuario no debería ver o permite modificar propiedades que no debería cambiar (asignación masiva).

Reglas internas relacionadas: API-RES-004.

6.4 REF-API-04 · API4:2023 - Consumo de recursos sin restricción

Nivel: Obligatorio | **Aplica a:** API | **Referencias:** API4:2023

Ausencia de límites de tasa, de tamaño de petición, de paginación o de tiempo de ejecución, lo que permite denegación de servicio o costos elevados.

Reglas internas relacionadas: SEG-AUT-004, API-RES-003, API-SEG-003.

6.5 REF-API-05 · API5:2023 - Autorización rota a nivel de función

Nivel: Obligatorio | **Aplica a:** API | **Referencias:** API5:2023

Usuarios comunes pueden invocar operaciones administrativas porque la autorización no se aplica a nivel de operación.

Reglas internas relacionadas: API-SEG-002.

6.6 REF-API-06 · API6:2023 - Acceso sin restricción a flujos de negocio sensibles

Nivel: Obligatorio | **Aplica a:** API | **Referencias:** API6:2023

Flujos como compras, reservas o registros pueden automatizarse de forma abusiva al no existir controles anti-automatización.

Reglas internas relacionadas: SEG-AUT-004, API-SEG-003, API-NET-005.

6.7 REF-API-07 · API7:2023 - Falsificación de solicitudes del lado del servidor (SSRF)

Nivel: Obligatorio | **Aplica a:** API | **Referencias:** API7:2023

La API obtiene recursos remotos a partir de URLs proporcionadas por el usuario sin validarlas.

Reglas internas relacionadas: API-SEG-005.

6.8 REF-API-08 · API8:2023 - Configuración de seguridad incorrecta

Nivel: Obligatorio | **Aplica a:** API | **Referencias:** API8:2023

CORS permisivo, cabeceras ausentes, métodos HTTP innecesarios, documentación interactiva expuesta en producción, mensajes de error detallados.

Reglas internas relacionadas: SEG-CFG-001, SEG-CFG-002, API-GOB-002.

6.9 REF-API-09 · API9:2023 - Gestión inadecuada del inventario

Nivel: Obligatorio | **Aplica a:** API | **Referencias:** API9:2023

Versiones antiguas o APIs no documentadas siguen expuestas sin control ni dueño.

Reglas internas relacionadas: API-VER-002, API-GOB-001.

6.10 REF-API-10 · API10:2023 - Consumo inseguro de APIs

Nivel: Obligatorio | **Aplica a:** API | **Referencias:** API10:2023

Se confía ciegamente en las respuestas de APIs de terceros sin validarlas ni limitar su impacto.

Reglas internas relacionadas: API-SEG-006.

7. OWASP ASVS 4.0.3 por capítulo

Resumen de los catorce capítulos de ASVS 4.0.3 con los requisitos más citados en los estándares internos. La lista completa de requisitos se consulta en la publicación oficial.

7.1 REF-ASVS-V1 · ASVS V1 - Arquitectura, diseño y modelado de amenazas

Nivel: Obligatorio | **Aplica a:** Web, API | **Referencias:** ASVS V1

Ciclo de desarrollo seguro, modelado de amenazas para cada cambio de diseño (V1.1.2) y arquitectura con controles centralizados.

Reglas internas relacionadas: SEG-GEN-001.

7.2 REF-ASVS-V2 · ASVS V2 - Autenticación

Nivel: Obligatorio | **Aplica a:** Web, API | **Referencias:** ASVS V2

Contraseñas de al menos 12 caracteres (V2.1.1), verificación contra contraseñas filtradas (V2.1.7), controles anti-automatización (V2.2.1) y almacenamiento con funciones de derivación de claves con sal (V2.4.1).

Reglas internas relacionadas: SEG-AUT-001, SEG-AUT-002, SEG-AUT-004.

7.3 REF-ASVS-V3 · ASVS V3 - Gestión de sesiones

Nivel: Obligatorio | **Aplica a:** Web, API | **Referencias:** ASVS V3

Invalidación de la sesión al cerrarla (V3.3.1), atributos Secure (V3.4.1), HttpOnly (V3.4.2) y SameSite (V3.4.3) en las cookies.

Reglas internas relacionadas: SEG-AUT-005.

7.4 REF-ASVS-V4 · ASVS V4 - Control de acceso

Nivel: Obligatorio | **Aplica a:** Web, API | **Referencias:** ASVS V4

Control de acceso aplicado en una capa de confianza del servidor (V4.1.1), mínimo privilegio (V4.1.3), denegar por defecto (V4.1.5), protección contra IDOR (V4.2.1) y CSRF (V4.2.2).

Reglas internas relacionadas: SEG-GEN-002, SEG-GEN-003, SEG-ACC-001, SEG-ACC-002, SEG-ACC-003.

7.5 REF-ASVS-V5 · ASVS V5 - Validación, sanitización y codificación

Nivel: Obligatorio | **Aplica a:** Web, API | **Referencias:** ASVS V5

Validación por lista blanca (V5.1.3), codificación de salida según el contexto (V5.3.3), consultas parametrizadas (V5.3.4), prevención de inyección de comandos (V5.3.8), XML sin entidades externas (V5.5.2) y no deserializar datos no confiables (V5.5.3).

Reglas internas relacionadas: SEG-INY-001 a SEG-INY-006.

7.6 REF-ASVS-V6 · ASVS V6 - Criptografía almacenada

Nivel: Obligatorio | **Aplica a:** Web, API | **Referencias:** ASVS V6

Algoritmos aprobados (V6.2.2), aleatorios criptográficamente seguros (V6.3.1) y gestión de secretos en una bóveda (V6.4.1).

Reglas internas relacionadas: SEG-CRI-001, SEG-CRI-002, SEG-CRI-003, SEG-DSK-002.

7.7 REF-ASVS-V7 · ASVS V7 - Manejo de errores y registro

Nivel: Obligatorio | **Aplica a:** Web, API | **Referencias:** ASVS V7

No registrar credenciales ni datos de pago (V7.1.1), registrar eventos de seguridad (V7.1.3) y mostrar mensajes de error genéricos (V7.4.1).

Reglas internas relacionadas: SEG-LOG-001, SEG-LOG-002, SEG-LOG-003.

7.8 REF-ASVS-V8 · ASVS V8 - Protección de datos

Nivel: Obligatorio | **Aplica a:** Web, API | **Referencias:** ASVS V8

Clasificación y protección de datos sensibles, cabeceras anti-caché y envío de datos sensibles en el cuerpo o cabeceras y nunca en la URL (V8.3.1).

Reglas internas relacionadas: SEG-CRI-005, API-SEG-007.

7.9 REF-ASVS-V9 · ASVS V9 - Comunicaciones

Nivel: Obligatorio | **Aplica a:** Web, API | **Referencias:** ASVS V9

TLS en todas las conexiones de clientes (V9.1.1) y en las comunicaciones internas entre servicios.

Reglas internas relacionadas: SEG-CRI-004.

7.10 REF-ASVS-V10 · ASVS V10 - Código malicioso

Nivel: Obligatorio | **Aplica a:** Web, API | **Referencias:** ASVS V10

Integridad del código y de las actualizaciones, ausencia de funcionalidades ocultas o puertas traseras.

Reglas internas relacionadas: SEG-DSK-003, SEG-CFG-004.

7.11 REF-ASVS-V11 · ASVS V11 - Lógica de negocio

Nivel: Obligatorio | **Aplica a:** Web, API | **Referencias:** ASVS V11

Los flujos de negocio se procesan en orden, con límites realistas y protección contra automatización abusiva.

Reglas internas relacionadas: API-NET-005, API-SEG-003.

7.12 REF-ASVS-V12 · ASVS V12 - Archivos y recursos

Nivel: Obligatorio | **Aplica a:** Web, API | **Referencias:** ASVS V12

Límite de tamaño de archivos (V12.1.1) y no usar el nombre proporcionado por el usuario para construir rutas (V12.3.1).

Reglas internas relacionadas: SEG-INY-007.

7.13 REF-ASVS-V13 · ASVS V13 - API y servicios web

Nivel: Obligatorio | **Aplica a:** Web, API | **Referencias:** ASVS V13

Las URLs no exponen información sensible como claves de API (V13.1.3), los métodos HTTP se validan (V13.2.1) y la entrada JSON se valida contra un esquema (V13.2.2).

Reglas internas relacionadas: API-DIS-002, API-SEG-001, API-SEG-004.

7.14 REF-ASVS-V14 · ASVS V14 - Configuración

Nivel: Obligatorio | **Aplica a:** Web, API | **Referencias:** ASVS V14

Componentes actualizados (V14.2.1), cabeceras de seguridad como CSP (V14.4.3) y HSTS (V14.4.5), y CORS con lista blanca de orígenes (V14.5.3).

Reglas internas relacionadas: SEG-CFG-001, SEG-CFG-002, SEG-CFG-003.

8. OWASP MASVS 2.x por grupo de controles

8.1 REF-MAS-STORAGE · MASVS-STORAGE - Almacenamiento

Nivel: Obligatorio | **Aplica a:** Móvil | **Referencias:** MASVS-STORAGE

STORAGE-1: los datos sensibles se almacenan de forma segura. STORAGE-2: la aplicación previene la fuga de datos sensibles (logs, capturas, copias de seguridad).

Reglas internas relacionadas: SEG-MOV-001, SEG-MOV-002, SEG-LOG-001.

8.2 REF-MAS-CRYPTO · MASVS-CRYPTO - Criptografía

Nivel: Obligatorio | **Aplica a:** Móvil | **Referencias:** MASVS-CRYPTO

CRYPTO-1: se usa criptografía robusta según las buenas prácticas. CRYPTO-2: las claves se gestionan según las buenas prácticas (almacén seguro de la plataforma).

Reglas internas relacionadas: SEG-CRI-001, SEG-MOV-001.

8.3 REF-MAS-AUTH · MASVS-AUTH - Autenticación y autorización

Nivel: Obligatorio | **Aplica a:** Móvil | **Referencias:** MASVS-AUTH

AUTH-1: protocolos seguros de autenticación y autorización con el backend. AUTH-2: autenticación local segura según la plataforma. AUTH-3: autenticación adicional para operaciones sensibles.

Reglas internas relacionadas: SEG-AUT-001, SEG-AUT-003, SEG-MOV-004.

8.4 REF-MAS-NETWORK · MASVS-NETWORK - Comunicación de red

Nivel: Obligatorio | **Aplica a:** Móvil | **Referencias:** MASVS-NETWORK

NETWORK-1: todo el tráfico de red es seguro según las buenas prácticas. NETWORK-2: se fija la identidad de los endpoints remotos bajo el control del desarrollador (pinning).

Reglas internas relacionadas: SEG-CRI-004, SEG-MOV-003.

8.5 REF-MAS-PLATFORM · MASVS-PLATFORM - Interacción con la plataforma

Nivel: Obligatorio | **Aplica a:** Móvil | **Referencias:** MASVS-PLATFORM

PLATFORM-1: uso seguro de mecanismos de comunicación entre procesos. PLATFORM-2: uso seguro de WebViews. PLATFORM-3: uso seguro de la interfaz de usuario.

Reglas internas relacionadas: SEG-MOV-002, SEG-MOV-005.

8.6 REF-MAS-CODE · MASVS-CODE - Calidad del código

Nivel: Obligatorio | **Aplica a:** Móvil | **Referencias:** MASVS-CODE

CODE-1: versión de plataforma actualizada. CODE-2: mecanismo para forzar actualizaciones. CODE-3: solo componentes sin vulnerabilidades conocidas. CODE-4: validación y sanitización de toda entrada no confiable.

Reglas internas relacionadas: SEG-MOV-007, SEG-CFG-003, SEG-INY-002.

8.7 REF-MAS-RESILIENCE · MASVS-RESILIENCE - Resiliencia ante ingeniería inversa y manipulación

Nivel: Recomendado | **Aplica a:** Móvil | **Referencias:** MASVS-RESILIENCE

RESILIENCE-1: valida la integridad de la plataforma. RESILIENCE-2: mecanismos anti-manipulación. RESILIENCE-3: dificulta el análisis estático. RESILIENCE-4: dificulta el análisis dinámico.

Reglas internas relacionadas: SEG-MOV-006.

8.8 REF-MAS-PRIVACY · MASVS-PRIVACY - Privacidad

Nivel: Obligatorio | **Aplica a:** Móvil | **Referencias:** MASVS-PRIVACY

PRIVACY-1: minimiza el acceso a datos y recursos sensibles. PRIVACY-2: previene la identificación del usuario. PRIVACY-3: es transparente sobre la recolección y uso de datos. PRIVACY-4: ofrece al usuario control sobre sus datos.

Reglas internas relacionadas: SEG-MOV-008.

9. Fuentes oficiales

OWASP Top 10: owasp.org/Top10. OWASP API Security Top 10: owasp.org/API-Security. OWASP ASVS: owasp.org/www-project-application-security-verification-standard. OWASP MASVS y MASTG: mas.owasp.org. Los contenidos de OWASP se publican bajo licencia Creative Commons BY-SA.